

CISM Domain 2A — Information Security Risk Assessment: Exam Essentials

Domain 2 (Information Security Risk Management) = 20% of the exam ≈ 30 of 150 questions. Part A covers the emerging risk/threat landscape (2A1), vulnerability & control deficiency analysis (2A2), and risk assessment & analysis (2A3).

Core Risk Vocabulary (memorize these)

Term	Meaning
Risk capacity	MAXIMUM risk the org can absorb and survive
Risk tolerance	Amount the org will accept for a SPECIFIC threat/asset pair (acceptable variation)
Risk appetite	Amount the org is WILLING to take on across all assets — sets the boundary for risk ACCEPTANCE

Inherent risk = risk with NO controls applied. **Residual risk** = risk remaining AFTER controls.

Risk = Likelihood × Impact, prioritized with asset value/criticality.

GRC = integrated approach to Governance (oversight), Risk Management (identify/assess/mitigate), and Compliance (document, monitor, enforce adherence).

Risk Identification (2A1)

- **Identifying assets comes FIRST** — you can't assess threats/vulnerabilities without knowing assets. Include third-party assets (vendors, cloud).
- Assess assets **that support business processes** (classic exam answer — not just those with tangible value).
- Techniques: workshops, structured techniques (data flow diagrams), what-if/scenario analysis, threat mapping — all **recurring** activities.
- Frameworks: **ISO 31000** (risk management guidelines), **NIST SP 800-37** (RMF).
- **Risk categories**: strategic, operational, reputational, compliance, technology, data, human resources.
- **Risk register** — living document tracking Risk ID, description, probability, impact, severity, response, owner; update at least annually.

Threat Actors & Threat Landscape

- **Hats**: white (authorized), black (malicious), gray (unauthorized but reports rather than exploits).
- **Actors**: script kiddies (low skill, prove themselves), hacktivists (cause-driven), criminal syndicates (financial gain, sophisticated), APTs (state-sponsored, long-term, well-funded), insiders (abuse authorized access), competitors (espionage).
- **Threat vector** = the pathway an attacker uses (phishing, malware, unpatched software). **Attack surface** = sum of ALL possible entry points. Castle analogy: vector = scaling a weak wall; surface = the whole castle.
- **Threat intelligence**: OSINT (public), proprietary (Mandiant, CrowdStrike), vulnerability databases (NVD, CVE, MITRE ATT&CK), IoCs (file hashes, IPs, domains), ISACs (sector sharing), CISA AIS (free real-time indicator exchange).

- **STIX = WHAT** is shared (common language); **TAXII = HOW** it's securely transferred. Assess intel by timeliness, accuracy, relevance, confidence scoring.
- **Likelihood factors:** volatility, velocity, proximity, interdependency, motivation, skill, visibility.

Vulnerabilities & Controls (2A2)

- Find vulnerabilities via: **scans** (automated, known weaknesses), **pen tests** (simulated attacks), **security reviews** (policies/configs), **audits** (compliance). Include process, procedural, physical AND technical.
- **Control deficiency** = control weak, ineffective, or missing. **Lack of training/awareness is a critical control deficiency**. Evaluate controls in context of other controls.
- **CVE** = dictionary of publicly known vulnerabilities (no severity score). **CVSS** = severity score. **NVD** (maintained by NIST, synced with MITRE CVE list) is where CVSS scores live.
- **Scan types:** credentialed (privileged — finds more) vs non-credentialed (what an attacker sees); intrusive (tries to exploit — sandbox only) vs non-intrusive (passive); network, application, web-app scans (XSS, SQLi).

Penetration Testing

- **White box** = full knowledge; **black box** = zero knowledge; **gray box** = partial (e.g., credentials).
- **Rules of engagement** define purpose, scope, systems, timing, constraints.
- Key techniques: **lateral movement** (spread to other systems), **privilege escalation** (gain higher rights), **persistence** (maintain long-term access).
- **Teams:** Red = offense, Blue = defense, Purple = improves red+blue effectiveness, White = referee.

Vulnerability scan	Penetration test
Automated tools; identifies KNOWN weaknesses (often CVEs)	Automated + manual; attempts to EXPLOIT vulnerabilities and assess impact
Almost anyone can run one; generally non-intrusive	Requires special skills; intrusive, may be disruptive
"Fire alarm" — warns, but not where/how severe	"Firefighter testing the alarm and sprinklers"

Aggregate risk across linked systems? → Penetration test — the only assessment that chains/exploits vulnerabilities sequentially (exam answer).

Security Control Baselines (SCBs)

- A **predefined minimum set of controls** aligned with risk tolerance and compliance; built from NIST 800-53, ISO 27001 Annex A, or policy.
- Must be **tailored** to the org (risk appetite, culture, resources); different baselines per **data classification**; cover people and processes, not just tech; approved by steering committee/senior leader.
- Baselines are **dynamic** — triggers for change: incidents (with root cause analysis), org changes (M&A, cloud migration), monitoring findings, external events, legal/regulatory changes, shifting risk appetite, new threats, system changes, vendor updates.

Risk Assessment & Analysis (2A3)

Risk assessment = the broad process (identify → analyze → evaluate → prioritize). **Risk analysis** = the step within it that evaluates likelihood and impact.

Three phases (exam focus):

1. **Risk Identification** — what could go wrong? (assets, threats, vulnerabilities, existing controls, consequences)
 2. **Risk Analysis** — how likely, and how bad? (probability × impact; qualitative or quantitative)
 3. **Risk Evaluation** — is it acceptable? Compare to risk appetite/tolerance → decide treatment
- **Risk management context** = internal + external environment shaping the program: strategic goals, regulatory environment (mandatory → takes priority), risk appetite, scope/boundaries.
 - **Risk scenario components**: threat type, actor, event, asset/resource, frequency, loss magnitude.
 - **Systemic risk** = one event hits many enterprises (e.g., Stuxnet, supply chain attacks); **contagious risk** = localized but hits multiple business partners quickly (e.g., phishing/ransomware); **cascading risk** = one failure triggers a chain reaction (small acceptable weaknesses compound).
 - **Approaches**: FAIR (breaks risk into components), HARM (builds on FAIR), PRA (probabilistic, NASA/nuclear). Others: Bayesian, bow-tie, Delphi (anonymous expert consensus), event tree (forward), fault tree (backward from failure), Markov, Monte Carlo (simulations).
 - **Change management** — every change can introduce vulnerabilities; the security manager sits on the change committee. ISACA: identifying risks in EARLY project stages saves cost.

Three Risk Analysis Methods

- **Qualitative** — SUBJECTIVE; low/medium/high scoring, risk matrix/heat map.
- **Quantitative** — OBJECTIVE; dollar values and formulas; proves controls are cost-effective.
- **Semi-quantitative (hybrid)** — qualitative terms mapped to numeric ranges (e.g., Rare=1 ... Frequent=5); Risk = Impact × Likelihood.

Formula	Meaning / Example
SLE = AV × EF	Single Loss Expectancy = Asset Value × Exposure Factor (%). Ex: \$1M building × 30% loss = \$300K
ALE = SLE × ARO	Annualized Loss Expectancy = SLE × Annualized Rate of Occurrence. Ex: \$300K × 0.2 (once per 5 yrs) = \$60K/yr
ARO examples	Twice a year = 2.0; once every 2 years = 0.5; once every 5 years = 0.2

Risk Treatment (know all four + examples)

Response	What it means
Avoid	Change business practices to eliminate the risk entirely (can hurt business opportunities)
Mitigate	Apply security controls to reduce probability and/or magnitude
Transfer	Shift some impact to another entity (e.g., cyber insurance)

Accept	Deliberately continue as normal — use when cost of mitigation > cost of impact
---------------	--

Quick Self-Check (from the handout)

1. Which assets belong in risk assessments? → **Those that support business processes**
2. Best way to assess aggregate risk across linked systems? → **Penetration test**
3. Why assess risk continuously? → **The risk environment is constantly changing**

Last-Minute Memory Hooks

- Appetite = willingness (org-wide); tolerance = per threat/asset; capacity = survival limit
- Inherent (before controls) → apply controls → residual (after)
- Assets first — no asset inventory, no risk assessment
- $SLE = AV \times EF$; $ALE = SLE \times ARO$
- CVE lists it, CVSS scores it, NVD stores the scores
- STIX = language, TAXII = transport
- Identify → Analyze → Evaluate → Treat (avoid / mitigate / transfer / accept)